

Reporte Ejecutivo de Gestión de Riesgos

1. Contexto y objetivo

Tras la auditoría externa reciente, que marcó varias debilidades en la forma en que se protegen los datos de los pacientes, se hizo un relevamiento de los riesgos más importantes de la clínica. Este documento resume lo que se encontró y qué se propone hacer al respecto, pensado para que la Dirección lo tenga en cuenta y apruebe las acciones sugeridas.

2. Metodología

El relevamiento se hizo con SimpleRisk, una herramienta que permite cargar los riesgos y ordenarlos según qué tan probable es que pasen y qué tan grave sería si pasan. En total se identificaron 7 riesgos concretos, relacionados con las historias clínicas, los datos de facturación, los accesos del personal y la continuidad del trabajo diario de la clínica.

3. Riesgos identificados

Riesgo	Nivel	Impacto potencial para la clínica
Acceso indebido a historias clínicas digitales	MUY ALTO	Exposición de datos de salud de pacientes; consecuencias legales y reputacionales graves.
Filtración de datos por proveedor de facturación	ALTO	Exposición de datos de facturación y obra social fuera del control directo de la clínica.
Phishing dirigido a personal administrativo	ALTO	Acceso no autorizado a sistemas internos a través de credenciales comprometidas.
Incumplimiento normativo de protección de datos de salud	ALTO	Sanciones regulatorias y daño reputacional ante una eventual auditoría de cumplimiento.
Pérdida de datos por falla en el proceso de backups	ALTO	Pérdida irreversible de historial médico ante una falla del servidor principal.
Caída prolongada del servidor de historias clínicas	MEDIO	Interrupción de la atención diaria de pacientes por falta de acceso al historial.
Acceso físico no autorizado al data center	MEDIO	Robo o sabotaje de equipamiento que aloja información sensible.

De los 7 riesgos relevados, 5 quedaron en nivel Alto o superior. Por una cuestión de tiempo, en esta primera etapa se armó un plan de acción concreto solo para los 3 más urgentes y más fáciles de resolver pronto (sección 4). Los otros dos quedan anotados y bajo seguimiento, para encararlos más adelante.

4. Planes de acción propuestos

A continuación se detallan las 3 acciones prioritarias definidas para reducir los riesgos de mayor impacto sobre la clínica.

Riesgo	Acción propuesta	Responsable	Plazo
Acceso indebido a historias clínicas	Implementar control de acceso por roles (RBAC) y registro de auditoría de accesos a historias clínicas.	Área de Seguridad de la Información	3 meses
Phishing a personal administrativo	Activar autenticación de múltiples factores (MFA) en cuentas críticas y capacitar al personal en detección de correos fraudulentos.	Área de Seguridad de la Información	2 meses
Incumplimiento normativo de protección de datos	Redactar y aprobar formalmente una política institucional de protección de datos de salud.	Dirección General	4 meses

5. Recomendación a la Dirección

Se recomienda aprobar los 3 planes de acción presentados, ya que atacan los problemas más urgentes detectados y van en línea con lo que ya había marcado la auditoría externa. También conviene ir pensando en una segunda etapa para el resto de los riesgos identificados, sobre todo lo relacionado con el proveedor de facturación y la revisión de los backups.

Este informe surge del relevamiento de riesgos hecho en SimpleRisk. El detalle técnico completo está disponible en el informe técnico adjunto.